Authentication cracking con Hydra

Luca Calzia - 13/11/2026

1. Obiettivo

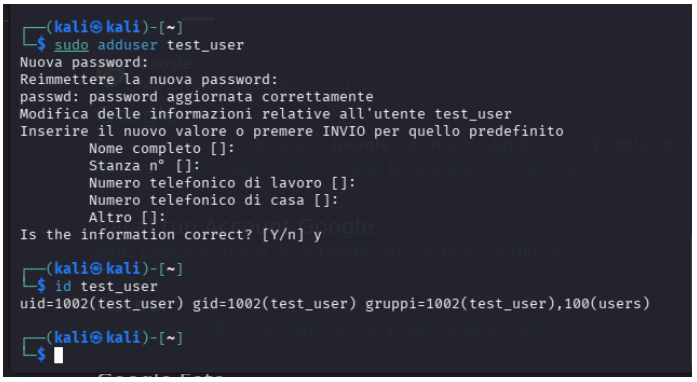
Il progetto ha avuto l'obiettivo di comprendere come funzionano gli accessi ai servizi di rete e di utilizzare Hydra per verificare credenziali deboli in un ambiente di laboratorio.

Nella prima fase abbiamo preparato un account su Kali Linux, verificato l'accesso SSH e provato Hydra con credenziali note e con due liste di candidati. Nella seconda fase abbiamo ripetuto le prove sul servizio FTP.

2. Preparazione del laboratorio

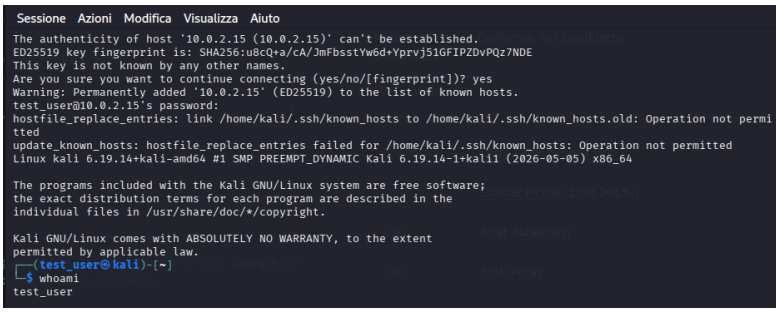
Abbiamo installato gli strumenti necessari e creato l'utente **test_user**, impostando la password **testpass**. Con **id test_user** abbiamo verificato che l'account esistesse. L'utente era dedicato alle prove: conoscere le credenziali ci ha permesso di controllare i risultati ottenuti con Hydra.

L'esistenza dell'account non dimostra, da sola, che l'accesso SSH sia consentito. Per questo abbiamo eseguito anche una connessione manuale.



3. Avvio di SSH e prova di accesso

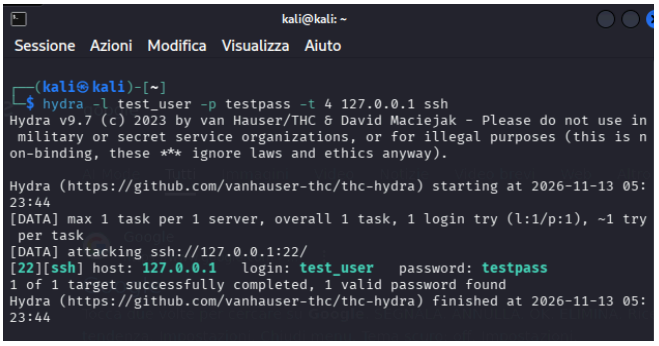
Abbiamo avviato SSH e controllato lo stato del servizio e la porta 22. L'indirizzo della macchina Kali era **10.0.2.15**. Abbiamo quindi effettuato l'accesso con l'utente creato e verificato l'identità della sessione con **whoami**.



Alla prima connessione era richiesta la conferma della chiave del server: abbiamo inserito **yes** per intero e poi la password. Il risultato **test_user** ha confermato l'accesso.

3.1 Prima prova con Hydra: credenziali note

Abbiamo fornito direttamente a Hydra l'utente **test_user** e la password **testpass**. Il messaggio **1 valid password found** ha confermato che lo strumento riconosceva un accesso valido. Si trattava di una verifica di funzionamento, non della scoperta di una password sconosciuta.



3.2 Analisi delle liste *Seclist*

Abbiamo esaminato due liste della raccolta SecLists. Il conteggio delle righe ha mostrato **8.295.455 nomi utente** e **1.000.000 di password**. Abbiamo inoltre verificato che test_user e testpass fossero presenti nei rispettivi file.

> Lista Numero di candidati Utenti 8.295.455
>
> Password 1.000.000
>
> Combinazioni massime: utenti × password **8.295.455.000.000**

Il numero massimo di combinazioni superava quindi ottomila miliardi. Una ricerca completa sarebbe stata poco pratica per il laboratorio.

3.3 Creazione di liste personali

Per ridurre la ricerca abbiamo usato due file personali: **usernames.txt**, con tre utenti, e **passwords.txt**, con cinque password. Ogni riga conteneva un candidato. Il numero massimo di combinazioni è così sceso a **3 × 5 = 15**.

Le credenziali corrette sono state incluse intenzionalmente per una dimostrazione controllata. In una ricerca alla cieca, una lista piccola può essere più veloce, ma non garantisce di contenere i valori corretti.

```
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/laboratorio-hydra

┌──(kali㉿kali)-[~]
└─$ cd laboratorio-hydra

┌──(kali㉿kali)-[~/laboratorio-hydra]
└─$ cat > usernames.txt <<'EOF'
admin
studente
test_user
EOF

┌──(kali㉿kali)-[~/laboratorio-hydra]
└─$ cat > passwords.txt <<'EOF'
123456
password
kali
testpass
letmein
EOF
```

3.4 Prove SSH con liste e gestione degli errori

Durante una prima prova con più attività parallele, Hydra si è fermato per errori di connessione. I log di SSH hanno mostrato una **penalità temporanea per autenticazioni fallite** applicata all'indirizzo 127.0.0.1. Il messaggio "nessuna password valida trovata" non dimostrava quindi che la password fosse errata: la prova non era stata completata.

```
┌──(kali㉿kali)-[~/laboratorio-hydra]
└─$ hydra -I -L usernames.txt -P passwords.txt -t 1 -V -f -o risultato_ftp.txt 10.0.2.15 ftp
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-11-13 09:37:07
[WARNING] Restorefile (ignored ...) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 1 task per 1 server, overall 1 task, 15 login tries (l:3/p:5), ~15 tries per task
[DATA] attacking ftp://10.0.2.15:21/
[ATTEMPT] target 10.0.2.15 - login "admin" - pass "123456" - 1 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "admin" - pass "password" - 2 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "admin" - pass "kali" - 3 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "admin" - pass "testpass" - 4 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "admin" - pass "letmein" - 5 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "studente" - pass "123456" - 6 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "studente" - pass "password" - 7 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "studente" - pass "kali" - 8 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "studente" - pass "testpass" - 9 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "studente" - pass "letmein" - 10 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "123456" - 11 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "password" - 12 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "kali" - 13 of 15 [child 0] (0/0)
[ATTEMPT] target 10.0.2.15 - login "test_user" - pass "testpass" - 14 of 15 [child 0] (0/0)
[21][ftp] host: 10.0.2.15   login: test_user   password: testpass
[STATUS] attack finished for 10.0.2.15 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-11-13 09:37:50

┌──(kali㉿kali)-[~/laboratorio-hydra]
└─$
```

Abbiamo ripetuto la prova con una sola attività e un intervallo di 10 secondi tra i tentativi. Hydra ha individuato **test_user** e **testpass** al quattordicesimo tentativo, fermandosi dopo il successo. L'opzione **-I** ha consentito di ignorare il file di ripristino lasciato dalla prova precedente.

Questa prova è un attacco a dizionario online: Hydra verifica i candidati contro il servizio, senza decifrare il traffico SSH o leggere direttamente la password memorizzata nel sistema.

4. Configurazione di FTP e prova manuale

Per la seconda fase abbiamo scelto **FTP**. Abbiamo installato il server **vsftpd** e il client **ftp**, quindi salvato una copia della configurazione originale. Abbiamo configurato il servizio per consentire l'accesso agli utenti locali e disabilitare quello anonimo.

Dopo il riavvio, il servizio risultava attivo. Il comando **ss** ha mostrato il processo vsftpd in ascolto sulla **porta 21**. Abbiamo quindi effettuato una connessione manuale con le credenziali test_user e testpass.

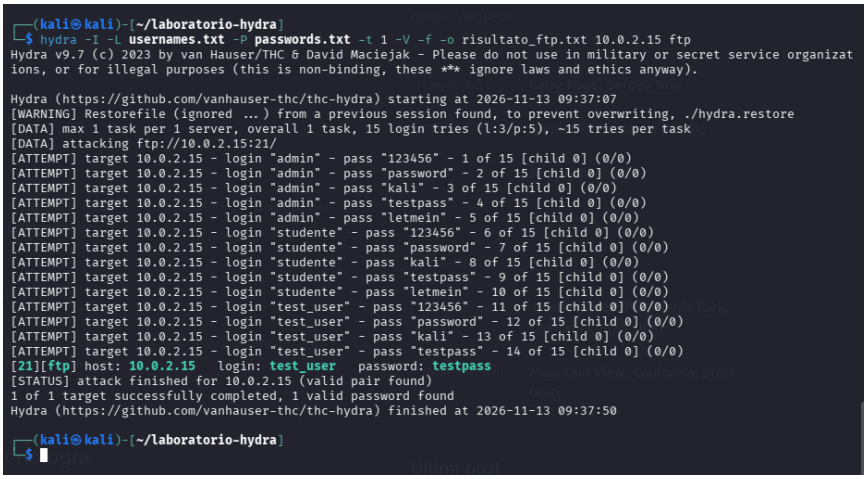
Il messaggio **230 Login successful** ha confermato l'autenticazione. Abbiamo poi chiuso la sessione con **bye**. Questa verifica ha accertato che servizio e credenziali funzionassero prima della prova automatica.



4.1. Ricerca delle credenziali FTP con Hydra

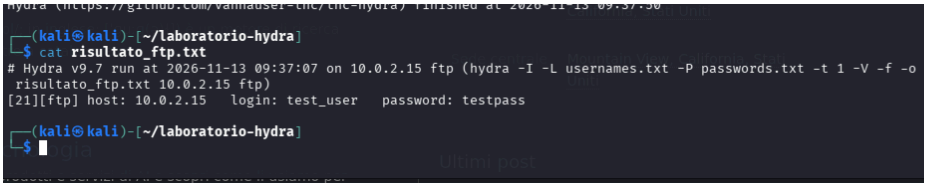
Abbiamo riutilizzato le liste personali per verificare l'accesso FTP. Hydra ha eseguito i tentativi uno alla volta, provando le combinazioni dei tre utenti e delle cinque password. Il modulo del servizio è stato cambiato da **ssh** a **ftp**.

L'opzione **-f** ha fermato la ricerca al primo successo. Il risultato dimostra che le credenziali presenti nelle liste sono state riconosciute dal server FTP.



4.2 Salvataggio dei risultati

L'opzione **-o** ha salvato il risultato FTP nel file **risultato_ftp.txt**. Con il comando seguente abbiamo verificato che il file contenesse la coppia di credenziali individuata.



5. Conclusioni

Le prove hanno mostrato che Hydra può automatizzare i tentativi di accesso sia su SSH sia su FTP. Nei due servizi sono state riconosciute le credenziali dell'account di laboratorio. Le liste personali hanno reso la ricerca breve e controllabile rispetto alle dimensioni delle liste SecLists.

Il risultato dipende dai candidati scelti: se la password corretta manca dalla lista, non può essere trovata con quella prova. Inoltre, le protezioni del servizio possono interrompere le connessioni, come è accaduto durante la prima ricerca SSH. La cifratura di SSH protegge il collegamento, ma non impedisce di tentare l'accesso con password candidate.

L'attività ha quindi evidenziato l'utilità di password robuste e di limiti ai tentativi di accesso. Al termine delle prove, SSH e FTP possono essere arrestati se non sono più necessari, mantenendo i file dei risultati.